

Table of Contents

Cisco Secure Workload — PCI DSS v4.0 Compliance Framework

Reference Design | Payment Card Industry Accounts

Version: 1.0 | **Standard:** PCI DSS v4.0 (March 2022)

Reader's Guide

Who this is for. Merchants and service providers with a Cardholder Data Environment (CDE) preparing for QSA assessment, AOCs, or self-assessment under PCI DSS v4.0; and QSAs cross-checking technical evidence.

Questions this reference design helps you answer:

- *Can I prove every system component currently "in scope" for PCI is actually in scope today, with no scope drift since last assessment? (Req 12.5.2)*
- *Req 1.2.1 calls for a current network diagram of CDE flows. What is the live, machine-generated artifact form of that diagram?*
- *Req 11.5.2 (change-detection on critical files) — what is my signal that nothing was added to the CDE between assessments?*
- *Req 10.2 logging — am I capturing audit-relevant events at the workload tier, not just at the network or SIEM layer?*
- *PCI DSS v4.0 introduced "in place and operating effectively" language and the customized approach. What does my continuous evidence story look like, vs. annual snapshots? (Req 12.4.2)*

What you'll need. A defined and documented CDE, your current PCI scope document, and your QSA's evidence request template (or last year's RoC sections).

Where to start. Sections 1–2 if scope is in motion; section 3 to walk requirement-by-requirement; sections 4–5 if you're inside the assessment window or preparing v4.0 transition evidence.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥2 weeks; export clusters; app-	Days 11–28

Phase	Goal	Key CSW actions	Typical duration
		owner signoff	
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- CDE isolation with simulation → enforce — Req 1 evidence at workload tier
- Live CDE flow map (Req 1.2.1) from ADM, not annual Visio
- CVE + reachability prioritisation for Req 6.3.3

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

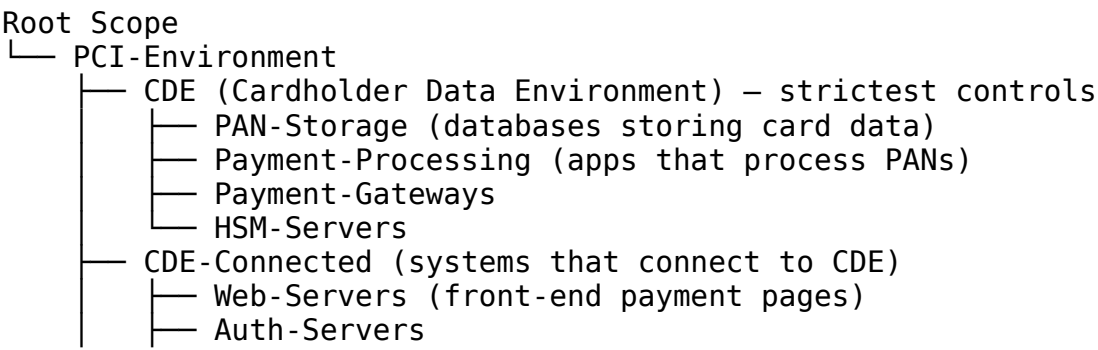
PCI DSS v4.0 introduces customized implementation approaches and strengthens network segmentation requirements. CSW can support evidence for aspects of PCI DSS Requirements 1 (network controls), 6 (vulnerability management), 10 (logging/monitoring), and 11 (security testing) where workload-level visibility and enforcement apply; confirm final scope and evidence sufficiency with your QSA.

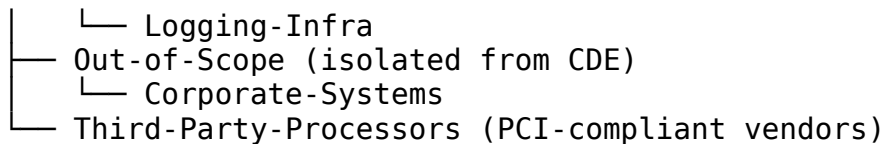
PCI DSS Requirement → CSW Capability Map

PCI Requirement	CSW Capability
Req 1 — Network Security Controls	Micro-segmentation, CDE isolation
Req 2 — Secure Configurations	Vulnerability detection, process monitoring
Req 6 — Vulnerability Management	Continuous vulnerability exposure visibility, CVSS prioritization
Req 7 — Access Control	Workload-level allowlist enforcement
Req 10 — Logging & Monitoring	Full flow + process telemetry
Req 11 — Security Testing	ADM baseline deviation detection

2. Cardholder Data Environment (CDE) Scoping

2.1 CDE Scope Architecture





2.2 Scope Reduction Strategy

CSW helps reduce PCI scope by proving isolation:

- ADM confirms zero communication between CDE and out-of-scope systems
 - Policy enforcement blocks any unapproved CDE connections
 - Segment isolation evidence available for QSA (Qualified Security Assessor)
-

3. PCI DSS v4.0 Control Implementation

Requirement 1 — Network Security Controls

1.2.1 — Configuration standards for network controls

CSW Policy: CDE-Isolation

DENY: Any → CDE (default deny all inbound)

ALLOW: Web-Servers → Payment-Processing (port 443 only)

ALLOW: Payment-Processing → PAN-Storage (port 5432/1521 – encrypted)

ALLOW: Auth-Servers → CDE (port 636 LDAPS only)

DENY: CDE → Internet (no direct internet access)

LOG: All policy violations with full context

1.3.1 — Inbound traffic to CDE restricted

- CSW enforces allowlist-only inbound to CDE scope
- Any unlisted source attempting CDE access triggers immediate alert

1.3.2 — Outbound traffic from CDE restricted

- CDE workloads blocked from initiating internet connections
- Only approved outbound paths (monitoring, logging) explicitly allowed

1.4.1 — Network controls between CDE and untrusted networks

- CSW micro-segmentation enforces at workload level — not just perimeter
- ADM provides continuous mapping of CDE communication paths

Requirement 6 — Vulnerability Management

6.3.3 — All software protected from known vulnerabilities

CSW UI → Investigate → Vulnerability Report

→ Scope: CDE

→ Filter CVSS ≥ 4.0

→ Export: CSV for tracking

Remediation SLAs:

Critical (CVSS 9.0+): 24 hours

High (CVSS 7.0-8.9): 7 days

Medium (CVSS 4.0-6.9): 30 days

6.4.1 — Web-facing applications protected

- CSW monitors all inbound flows to web-facing CDE workloads
- Anomalous request patterns surfaced via forensic telemetry

Requirement 7 — Access Control

7.2.1 — Access to system components and cardholder data restricted

- CSW scope-based policy: only approved workload identities access CDE
- Workload-level enforcement can catch gaps beneath or between network-security-control views; it complements, not replaces, PCI network security controls
- Process-level access audit: which process on which workload touched CDE

7.2.5 — Default and unnecessary accounts removed

- CSW process monitoring detects unexpected processes on CDE workloads
- Alert on new process hash not seen in ADM baseline

Requirement 10 — Logging & Monitoring

10.2.1 — Audit logs capture required events

CSW captures per CDE workload:

- All inbound/outbound network connections (source, dest, port, protocol)
- Process activity (name, hash, parent process, user context)
- Policy violations (blocked connections with full 5-tuple)
- Anomaly events (baseline deviations)

10.3.1 — Audit logs protected from destruction

- CSW telemetry stored in tamper-resistant cluster storage
- Export pipeline to immutable SIEM/SYSLOG for long-term retention
- PCI DSS requires 12-month retention (3 months immediately available)

10.4.1 — Audit logs reviewed daily

- CSW dashboard provides daily summary of CDE events
- Automated alert export to SOC/SIEM eliminates manual review burden

Requirement 11 — Security Testing

11.3.1 — External vulnerability scans quarterly

- CSW provides continuous vulnerability exposure context for workloads it observes
- Use CSW reports as supplementary evidence; they do not replace required PCI external ASV scans or other mandated testing unless explicitly accepted by your QSA for a documented customized approach

11.4.1 — Penetration testing methodology

- ADM baseline used as pre-pentest reference
- Post-pentest ADM comparison detects any new paths discovered
- Forensic telemetry captures all pentest activity for review

4. Evidence Package for QSA

Evidence Item	CSW Source	PCI Requirement	Frequency
CDE network policy export	Defend → Policy Workspaces	Req 1	Per assessment
CDE inbound/outbound flow log	Investigate → Flow Search	Req 1, Req 10	Continuous
Policy violation report	Alerts → Triggered Events	Req 10	Monthly
Vulnerability exposure report (CDE)	Investigate → Vulnerability	Req 6, Req 11	Weekly
CDE scope membership snapshot	Inventory → Export	Req 1, Req 7	Monthly
Anomaly detection log	Alerts → Dashboard	Req 10, Req 11	Monthly
ADM dependency map (CDE)	Investigate → ADM	Req 1	Quarterly
Process audit log (CDE)	Investigate → Process Search	Req 10	On-demand

5. PCI DSS v4.0 New Requirements CSW Addresses

New in v4.0	CSW Response
12.3.2 — Targeted risk analysis for each requirement	CSW vulnerability + ADM data feeds risk analysis
1.2.1 — All traffic flows documented and approved	ADM produces observed-flow documentation for CSW-instrumented paths; human approval and non-CSW

New in v4.0	CSW Response
	paths remain part of CDE documentation
6.3.3 — All vulnerabilities addressed per risk ranking	Continuous vulnerability exposure view with CVSS-ranked remediation inputs
10.7.2 — Failures of critical security controls detected	Sensor offline alerts, policy enforcement gap detection

Related Frameworks

- [ISO/IEC 27001:2022](#) — most PCI-attested organisations also operate an ISO 27001 ISMS.
- [NIST SP 800-53 Rev 5](#) — useful when PCI evidence is being reused across a federal control programme.
- [DORA \(EU 2022/2554\)](#) — for EU payment-services entities, PCI scope and DORA Pillar 1 share substantial evidence.
- [NIST SP 800-207](#) — the segmentation pattern underneath PCI Reqs 1, 7, 11.

Replace [Customer Name] and bracketed fields before customer delivery.